COMPTIA SECURITY+ SY0-701 | DOMÍNIO 5 · GESTÃO DE PROGRAMA DE SEGURANÇA E GOVERNANÇA (20%)

Security+ 5.1 · Data Roles & Responsibilities

Mestre CyberSec · **Aula 5.1 — Data Roles & Responsibilities** (2:27) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Owner (negócio — define classificação/who accesses — o GERENTE); Controller (determina o PROPÓSITO e uso legal — LGPD/GDPR); Processor (processa em nome do controller — cloud provider); Custodian (TI — ADMINISTRA/implementa o owner pede).

💡 Highlights que a prova CompTIA cobra

- Owner=gerente do negócio (define); Custodian=TI (implementa)
- Controller (LGPD) define o PORQUÊ; Processor processa POR ORDEM

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'the person who determines how data is used'=data controller

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 5.1 — Data Roles & Responsibilities)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Proprietário dos Dados / Responsável pelos Dados (N/A)

Líder de negócio responsável por um conjunto de dados específico; define sua classificação, regras de acesso e requisitos de proteção.

⚠️ ***Armadilha CompTIA:*** *Owner define política/classificação; Custodian implementa. Se a questão diz 'gerente de negócio define quem acessa', é Data Owner.*

• Controlador de Dados (N/A)

Entidade que determina a finalidade e os meios de processamento de dados pessoais e deve garantir base legal sob GDPR/LGPD.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'determina como os dados são usados' ou 'define o propósito' = Data Controller. Não é necessariamente TI/custodian.*

• Operador de Dados / Processador de Dados (N/A)

Terceiro que processa dados pessoais em nome e sob as instruções do controlador de dados.

⚠️ ***Armadilha CompTIA:*** *Processor age por ordem do controller. Provedor de nuvem que processa dados do cliente é processor; se decide finalidade, vira controller.*

• Custodiante de Dados (N/A)

Função de TI/segurança responsável por implementar e manter controles técnicos para proteger dados conforme direcionado pelo proprietário dos dados.

⚠️ ***Armadilha CompTIA:*** *Custodian faz administração prática (backup, criptografia, acessos). Owner define, Custodian implementa.*

• Gestor de Dados (N/A)

Função focada na qualidade dos dados, metadados e garantia de que os dados sejam usados conforme as políticas de governança.

⚠️ ***Armadilha CompTIA:*** *Steward cuida de qualidade/política; não confunda com Owner (responsabilidade) nem Custodian (implementação técnica).*

• Encarregado de Proteção de Dados (DPO)

Função independente exigida por leis de privacidade como GDPR/LGPD para monitorar conformidade, aconselhar sobre proteção de dados e ser ponto de contato com autoridades.

⚠️ ***Armadilha CompTIA:*** *DPO aconselha/monitora; não define finalidade (Controller) nem implementa controles (Custodian).*

- **Regulamento Geral de Proteção de Dados (GDPR)**

Regulamento de privacidade da UE que define obrigações de controlador/operador, direitos dos titulares e processamento legal de dados pessoais.

⚠️ ***Armadilha CompTIA:*** *GDPR usa Controller/Processor. Se a questão cita UE, base legal ou direitos do titular, pense GDPR.*

- **Lei Geral de Proteção de Dados (LGPD)**

Lei brasileira de proteção de dados inspirada no GDPR; define deveres do controlador e do operador para dados pessoais.

⚠️ ***Armadilha CompTIA:*** *Equivalente brasileiro do GDPR. Controlador define finalidade; operador processa por ordem. Não confunda com custodian técnico.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Proprietário dos Dados (Data Owner) vs Custodiante Técnico (Data Custodian)

🏠 **Analogia Intuitiva:** O dono da joalheria versus o chaveiro/gerente do cofre da loja. O dono da joalheria (Data Owner) decide quais joias são compradas, quanto vale cada anel de diamante e quem tem autorização para tocar nas peças. O chaveiro (Data Custodian - TI) não decide nada sobre o valor do ouro: ele apenas cuida da lubrificação do cofre, faz cópias das chaves (backups) e garante que o alarme esteja ligado.

🔍 **Causa Raiz / Por que foi criado:** A crença errônea de que a equipe de TI é dona dos dados da empresa, levando administradores de redes a tomar decisões comerciais arriscadas sobre o que pode ser compartilhado ou excluído.

🛡️ **Visão do Auditor de GRC:** Verificar se cada repositório ou tabela de dados possui um Data Owner formalmente nomeado (gerente de negócios) e se os administradores de TI operam estritamente como Data Custodians sob autorização expressa.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'business manager who classifies the data, determines sensitivity, and defines access rights' = Data Owner. Em contraste, 'technician responsible for backups, maintenance, and technical implementation' = Data Custodian / Steward.

📌 Controlador de Dados (Data Controller) vs Operador/Processador (Data Processor)

🏠 **Analogia Intuitiva:** O anfitrião da festa de casamento versus a empresa terceirizada de buffet e garçons. O anfitrião (Data Controller) decide quem entra na lista de convidados, escolhe o cardápio e determina o que será feito com as fotos da festa. A empresa de buffet terceirizada (Data Processor) apenas frita os salgados e serve as mesas conforme o contrato assinado, sendo proibida de usar a lista de convidados para vender seus próprios produtos.

🔍 **Causa Raiz / Por que foi criado:** O uso maciço de computação em nuvem (SaaS, IaaS) onde empresas contratam provedores externos para armazenar e processar dados, exigindo divisão jurídica clara de responsabilidades perante a lei.

🛡️ **Visão do Auditor de GRC:** Fiscalizar os contratos de processamento de dados (DPAs - Data Processing Agreements): verificar se estipulam que o Operador (Processor) só age sob instruções do Controlador e se prevê notificação de violações em menos de 72 horas.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'entity that determines the purposes and means of processing personal data' = Data Controller. 'Third party that processes personal data on behalf of the controller (e.g. AWS, cloud payroll provider)' = Data Processor.

📌 Encarregado de Proteção de Dados (Data Protection Officer - DPO)

🏠 **Analogia Intuitiva:** O inspetor independente da vigilância sanitária ou o ombudsman de compliance instalado dentro de uma indústria farmacêutica: ele não responde à diretoria de vendas nem à equipe de produção; seu papel exclusivo é fiscalizar se os remédios e as instalações estão rigorosamente em conformidade com as leis do país e atender fiscalizações do Ministério Público.

🔍 **Causa Raiz / Por que foi criado:** Conflito de interesses corporativo: executivos tendem a priorizar lucros e vendas rápidas, negligenciando a privacidade dos titulares caso não haja um papel autônomo com reporte direto à alta cúpula e aos órgãos reguladores.

🛡️ **Visão do Auditor de GRC:** Verificar se o DPO possui independência comprovada (não acumula função de CISO ou TI que gere conflito), se seus canais de contato estão publicados publicamente para os titulares e se participa de decisões de novos produtos.

> ⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'independent executive responsible for overseeing data protection strategy, advising on GDPR/LGPD compliance, and acting as liaison to supervisory authorities' = Data Protection Officer (DPO).

📌 Titular dos Dados (Data Subject) e Direitos de Privacidade

🏠 **Analogia Intuitiva:** O cidadão que deixa sua mala no guarda-volumes da rodoviária: a estação tem a custódia temporária da mala para guardá-la em segurança, mas a mala e tudo o que está dentro pertencem ao cidadão. Ele tem o direito inegável de voltar ao guichê, inspecionar o que está na mala, corrigir uma etiqueta errada ou exigir a mala de volta e levar embora a qualquer momento.

🔍 **Causa Raiz / Por que foi criado:** O modelo de negócios da era da informação que tratava pessoas como mercadoria e explorava seus dados indefinidamente sem seu conhecimento ou controle.

🛡️ **Visão do Auditor de GRC:** Testar os mecanismos de autoatendimento para titulares (Data Subject Access Requests - DSAR): verificar se a empresa responde a pedidos de cópia, retificação e exclusão de dados dentro do prazo legal (ex: 15 dias na LGPD, 30 dias no GDPR).

> ⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'the identified or identifiable living individual whose personal data is being gathered or processed' = Data Subject.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Diretor financeiro decide quem no departamento pode visualizar relatórios de contas a pagar e estabelece nível de sigilo das planilhas	**Proprietário dos Dados (Data Owner)**
Administrador de sistemas configura a rotina noturna de backup e executa a criptografia das fitas magnéticas conforme a política corporativa	**Custodiante dos Dados (Data Custodian / Steward)**
Loja de comércio eletrônico decide coletar endereços de clientes para entregar mercadorias e define o propósito comercial dessa coleta	**Controlador de Dados (Data Controller)**
Provedor de nuvem terceirizado armazena registros de folha de pagamento sob estritas instruções e ordens do cliente contratante	**Operador / Processador de Dados (Data Processor)**
Profissional independente nomeado para fiscalizar o cumprimento das leis de privacidade e dialogar diretamente com a autoridade nacional	**Encarregado de Proteção de Dados (Data Protection Officer - DPO)**
Cidadão solicita formally que uma operadora de telefonia apague todos os seus registros pessoais após o cancelamento do contrato	**Direito do Titular dos Dados (Data Subject Right / Right to Erasure)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

A equipe de marketing de uma varejista quer usar históricos de compras de clientes para um novo programa de análise de fidelidade. O jurídico pergunta quem deve determinar a finalidade lícita e a base legal para o tratamento dos dados pessoais sob GDPR e LGPD. Qual papel é responsável por essa decisão?

A) Proprietário dos Dados (Data Owner) para atender a normas regulatórias obrigatórias de governança

B) Operador dos Dados (Data Processor) dentro dos limites formais de apetite a risco da organização

C) Controlador dos Dados (Data Controller)

D) Custodiante dos Dados (Data Custodian) em conformidade com critérios de análise de impacto no negócio

QUESTÃO 2 · CENÁRIO DE EXAME

Um fornecedor de software como serviço hospeda dados de folha de pagamento de uma indústria. A indústria decide por que os dados são tratados e fornece instruções documentadas, enquanto o fornecedor apenas processa os dados para prestar o serviço de folha. Qual papel de dados o fornecedor SaaS possui?

A) Operador dos Dados (Data Processor)

B) Controlador dos Dados (Data Controller)

C) Proprietário dos Dados (Data Owner) em conformidade com critérios de análise de impacto no negócio

D) Encarregado de Proteção de Dados (DPO)

QUESTÃO 3 · CENÁRIO DE EXAME

Depois que um proprietário de negócio classifica registros financeiros como restritos e aprova acesso para uma nova equipe de contabilidade, o departamento de TI cria as contas, aplica criptografia, configura backups e documenta as mudanças. Qual papel a TI está exercendo?

A) Proprietário dos Dados (Data Owner) assegurando a responsabilização e supervisão de fornecedores

B) Custodiante dos Dados (Data Custodian)

C) Controlador dos Dados (Data Controller)

D) Operador dos Dados (Data Processor)

QUESTÃO 4 · CENÁRIO DE EXAME

Um gerente de faturamento de hospital é responsável por decidir se os registros de faturamento de pacientes são confidenciais ou restritos e quais departamentos do hospital podem acessá-los. Qual papel de dados o gerente de faturamento representa principalmente?

A) Controlador dos Dados (Data Controller)

B) Custodiante dos Dados (Data Custodian)

C) Operador dos Dados (Data Processor)

D) Proprietário dos Dados (Data Owner)

QUESTÃO 5 · CENÁRIO DE EXAME

Uma empresa precisa de uma pessoa para monitorar independentemente a conformidade com o GDPR, aconselhar sobre avaliações de impacto à proteção de dados e atuar como ponto de contato com a autoridade supervisora. Qual papel deve ser atribuído?

A) Encarregado de Proteção de Dados (DPO)

B) Curador dos Dados (Data Steward) preservando a cadeia de custódia e a integridade forense

C) Controlador dos Dados (Data Controller) sob acordos formais de nível de serviço e operação

D) Custodiante dos Dados (Data Custodian) demonstrando diligência e cuidado devidos juridicamente defensáveis

QUESTÃO 6 · CENÁRIO DE EXAME

Uma empresa usa uma plataforma terceirizada de marketing por e-mail para enviar promoções. A plataforma pode processar endereços de e-mail de clientes apenas conforme instruções documentadas da empresa e não pode usar os dados para seu próprio marketing. Qual papel a plataforma possui?

A) Controlador dos Dados (Data Controller)

B) Proprietário dos Dados (Data Owner) sob acordos formais de nível de serviço e operação

C) Operador dos Dados (Data Processor)

D) Curador dos Dados (Data Steward) em conformidade com exigências legais de privacidade de dados

QUESTÃO 7 · CENÁRIO DE EXAME

Um analista de governança mantém metadados de negócio, documenta linhagem de dados, resolve problemas de qualidade de dados e garante que os departamentos usem definições consistentes para registros de clientes. Qual papel o analista está exercendo?

A) Custodiante dos Dados (Data Custodian)

B) Proprietário dos Dados (Data Owner) demonstrando diligência e cuidado devidos juridicamente defensáveis

C) Operador dos Dados (Data Processor)

D) Curador dos Dados (Data Steward)

QUESTÃO 8 · CENÁRIO DE EXAME

Sob a LGPD, uma empresa brasileira de comércio eletrônico decide por que dados pessoais serão coletados, por quanto tempo serão retidos e qual base legal se aplica a cada atividade de tratamento. Qual papel a empresa está exercendo?

A) Operador dos Dados (Data Processor) demonstrando diligência e cuidado devidos juridicamente defensáveis

B) Controlador dos Dados (Data Controller)

C) Custodiante dos Dados (Data Custodian) fornecendo métricas quantitativas de risco para a diretoria

D) Encarregado de Proteção de Dados (DPO)

QUESTÃO 9 · CENÁRIO DE EXAME

Um administrador de segurança recebe uma solicitação aprovada do proprietário dos dados para conceder acesso somente leitura a um grupo de análise e, em seguida, provisiona o papel, atualiza a lista de controle de acesso e registra a mudança. Qual papel o administrador de segurança está exercendo?

A) Custodiante dos Dados (Data Custodian)

B) Proprietário dos Dados (Data Owner) fornecendo métricas quantitativas de risco para a diretoria

C) Controlador dos Dados (Data Controller)

D) Operador dos Dados (Data Processor)

QUESTÃO 10 · CENÁRIO DE EXAME

A unidade de negócio de uma empresa multinacional decide coletar dados de localização de clientes para prevenção de fraude e define o período de retenção. O escritório de privacidade aconselha sobre conformidade e monitora riscos, enquanto um provedor de nuvem armazena os dados. Quem é o controlador dos dados para esse tratamento?

A) O provedor de nuvem que hospeda os dados fornecendo métricas quantitativas de risco para a diretoria

B) O escritório de privacidade que aconselha sobre conformidade para atender a normas regulatórias obrigatórias de governança

C) A equipe de segurança de TI que implementa controles dentro dos limites formais de apetite a risco da organização

D) A unidade de negócio/empresa que decide a finalidade e os meios

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Controlador dos Dados (Data Controller)

O Controlador de Dados determina as finalidades e os meios do tratamento de dados pessoais e garante que exista uma base legal sob GDPR/LGPD. O Proprietário dos Dados geralmente cuida da classificação de negócio e decisões de acesso, o Operador atua segundo instruções do controlador, e o Custodiante implementa e administra controles técnicos.

Questão 2: Alternativa A — Operador dos Dados (Data Processor)

O fornecedor SaaS é um Operador de Dados porque processa dados pessoais em nome do controlador e apenas conforme instruções documentadas. A indústria é a controladora, enquanto proprietário e DPO são papéis internos de governança e supervisão, não o papel de tratamento do fornecedor.

Questão 3: Alternativa B — Custodiante dos Dados (Data Custodian)

A TI atua como Custodiante dos Dados ao implementar e administrar os controles técnicos e as mudanças de acesso solicitadas pelo Proprietário dos Dados. O proprietário toma decisões de classificação e acesso, o controlador determina a finalidade do tratamento, e o operador trata dados em nome de um controlador.

Questão 4: Alternativa D — Proprietário dos Dados (Data Owner)

O gerente de faturamento é um Proprietário dos Dados porque esse papel de negócio é responsável pela classificação dos dados e por determinar quem pode acessá-los. O custodiante administra controles, o controlador determina finalidades legais de tratamento, e o operador atua em nome de um controlador.

Questão 5: Alternativa A — Encarregado de Proteção de Dados (DPO)

O Encarregado de Proteção de Dados (DPO) monitora a conformidade, aconselha sobre riscos de privacidade e DPIAs, e atua como contato com reguladores. O Curador dos Dados foca em qualidade e metadados, o Controlador toma decisões de tratamento, e o Custodiante implementa controles técnicos.

Questão 6: Alternativa C — Operador dos Dados (Data Processor)

A plataforma é um Operador de Dados porque processa dados pessoais em nome da empresa e apenas para as finalidades instruídas por ela. A empresa é a controladora, o proprietário gerencia classificação e acesso de negócio, e o curador cuida de qualidade e governança de dados.

Questão 7: Alternativa D — Curador dos Dados (Data Steward)

Um Curador dos Dados gerencia qualidade, metadados, linhagem e definições de negócio consistentes. O Custodiante cuida da administração técnica, o Proprietário é responsável por classificação e acesso, e o Operador atua conforme instruções de um controlador.

Questão 8: Alternativa B — Controlador dos Dados (Data Controller)

A empresa é um Controlador de Dados porque determina a finalidade, a retenção e a base legal para o tratamento de dados pessoais sob a LGPD. O Operador segue instruções, o Custodiante implementa controles, e o DPO monitora e aconselha em vez de tomar essas decisões de negócio.

Questão 9: Alternativa A — Custodiante dos Dados (Data Custodian)

O administrador de segurança é um Custodiante dos Dados porque implementa e administra a decisão de controle de acesso tomada pelo Proprietário dos Dados. O Proprietário decide quem recebe acesso, o Controlador determina finalidade e legalidade do tratamento, e o Operador atua em nome de um controlador.

Questão 10: Alternativa D — A unidade de negócio/empresa que decide a finalidade e os meios

A unidade de negócio/empresa é o Controlador dos Dados porque determina a finalidade e os meios do tratamento. O provedor de nuvem provavelmente é um Operador, o escritório de privacidade/DPO aconselha e monitora, e a segurança de TI atua como Custodiante ao implementar controles.